

Dynamic URL / Potential Arbitrary File Read

Assessment Identifier: **WS-STA-04** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: HIGH	CVSS: 7.5	CWE: CWE-939
OWASP: A01 / potentially A10	WASC ID: N/A	Confidence: High candidate
Target / Component: sdk/python/src/worldmonitor_sdk/__init__.py	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/sdk/python/src/worldmonitor_sdk/__init__.py	Parameter: Caller-controlled URL parameter in SDK client

1. Description

Static analysis identified dynamic URL handling in the Python SDK that may allow an attacker-controlled URL to reach a file or network retrieval operation. The complete source-to-sink flow must be verified.

2. Steps to Reproduce

- Run the SDK in an isolated local environment.
- Identify the URL-accepting function.
- Determine whether its URL is caller-controlled.
- Supply a harmless URL hosted by a local test server.
- Observe whether the SDK attempts retrieval.

3. Controlled Proof of Concept

Safe Proof of Concept:
Use only a local HTTP server such as http://127.0.0.1:8000/test.txt and verify that the SDK attempts the request. Do not access cloud metadata, internal corporate systems, or third-party infrastructure.

4. Business & Security Impact

If arbitrary destinations are accepted, the application may access unintended local or remote resources.

5. Remediation Recommendations

Primary Fix: Allowlist URL schemes and destinations, validate hosts, restrict outbound network access, and reject unexpected protocols or destinations.

- Restrict URL schemes strictly to HTTPS.
- Validate that destination hostnames belong to the official World Monitor API domains.
- Disallow file://, gopher://, or internal IP addresses (e.g., 169.254.169.254, 127.0.0.1, 10.0.0.0/8).

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*